CAPSTONE · CCC104 · CSCC COHORT 11

Cybersecurity Risk Assessment & Ransomware Resilience Strategy



A multi-site healthcare provider: FAC-A (Main) and FAC-B (Satellite)

Prepared by the Consultative Capstone Team | Project ID CAP-20261022-E1E80DDE52 | 7 November 2026

Meet the research team

AC **Alphonsus Stephen Chibuike**

Team Lead and Governance Coordinator

C11/26/CSCC/17451

LR **Laban Emmanuel Rakum**

Assessment and NIST CSF Lead

C11/26/CSCC/17472

NA **Nicholas Atacha**

Risk Assessment Lead

C11/26/CSCC/17395

OD **Oreofe Dada**

Security Architecture Lead

C11/26/CSCC/17383

OG **Owiliwa Clever Goodluck**

Technical Validation and Backup Recovery Lead

C11/26/CSCC/17416

OA **Oyewale Akinrinde**

Incident Response, Roadmap and Dashboard Lead

C11/26/CSCC/17529

Certified Cybersecurity Consultant (CSCC) Cohort 11 | CCC104 Capstone | Submission: 7 November 2026

When ransomware hits, care slows down



Patient care

EHR, registration and scheduling go dark across both facilities, delaying clinical work.



Sensitive data

Patient and billing records are exposed to theft, encryption or loss.



Recovery cost

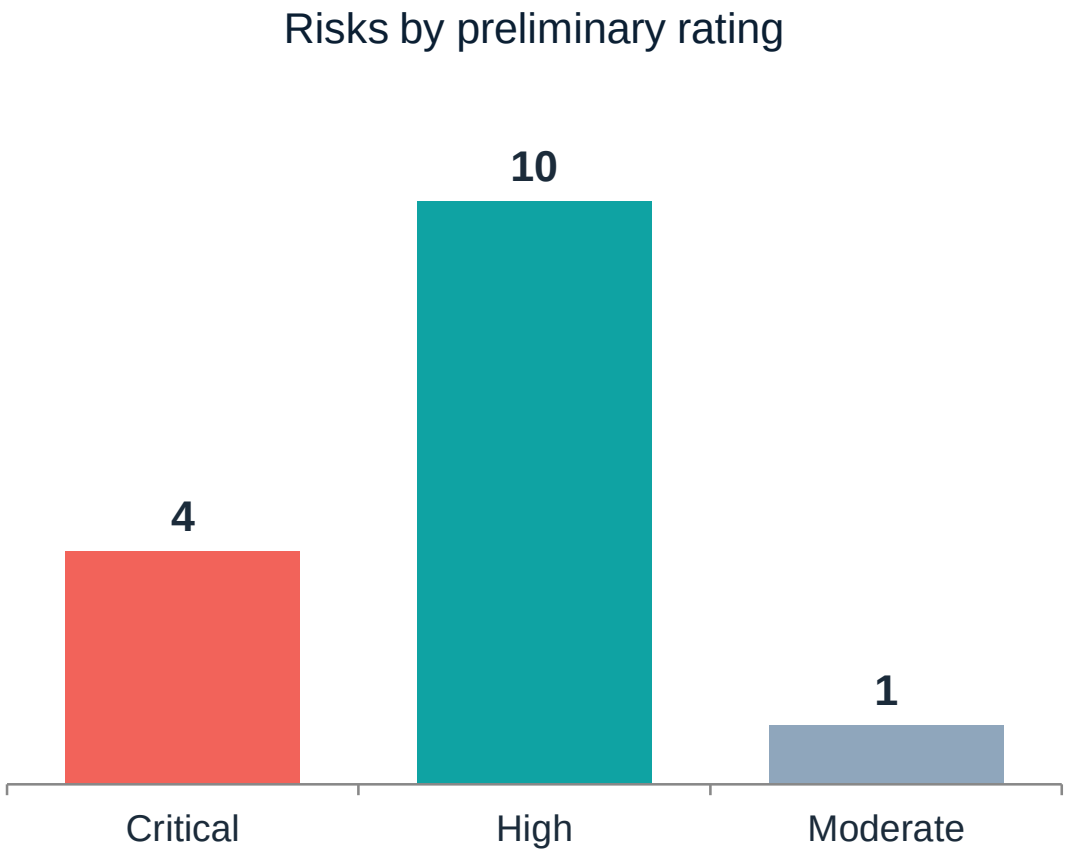
Downtime, rebuild effort and lost billing add financial and operational damage.

The question: how resilient is a simulated Nigerian private healthcare provider, and what must change in 90 days?

Five exposure areas shape the ransomware risk

Identity & privileged access	Everyday accounts used for admin work, no MFA for internal staff and a single domain controller (SV-04).
Endpoints & patching	21 of 66 PCs run Windows 10 without Extended Security Updates; Defender is standalone with no central EDR.
Network & remote access	Flat networks, guest Wi-Fi on the internal LAN and internet-facing RDP forwarded to SV-02.
Monitoring & detection	No central log store or SIEM; logs stay scattered across endpoints and servers.
Backup isolation	Veeam (SV-06) runs on the host it protects, the backup NAS is domain-joined and the FAC-B NAS is not backed up.

15 risks, four of them critical



CRITICAL RISKS

R03 Admin account compromise

R06 Flat network lets ransomware spread

R08 Backups reachable from compromised domain

R10 Internet-facing RDP to the EHR server

Preliminary ratings, pending scoring reconciliation.

Seven domains of defence-in-depth

Identity & access

MFA, role-based access, separate admin accounts

Endpoint security

Managed protection, 14/30-day patching, hardening

Network & access

Seven zones, default-deny, VPN with MFA

Monitoring

Wazuh SIEM, alerts on events 4688, 4625, 4732

Patch & vulnerability

Lifecycle inventory, Server 2016 exit by 12 Jan 2027

Third-party access

Vendor register, no shared credentials

Backup resilience

3-2-1-1 copies, isolated NAS, tested restores

P0 first

Days 1 to 30: MFA, RDP removal, backup isolation and initial endpoint protection.

Proof in the lab: three controls demonstrated

9/9

Access decisions as expected

3 allowed, 6 cross-role denied (NTFS role-based access)

4688

Process creation captured

Audit policy plus command-line logging verified in the Security log

3/3

Files restored intact

Synthetic records matched on SHA-256 after restore

Boundaries: one workstation, synthetic data, no live ransomware. This supports the design but is not production validation.

Operation DryRUN exposed ten gaps

28 Oct 2026

10

gaps found (G1 to G10)

8

corrective actions (R1 to R8)

Discussion-based: RDP compromise leading to EHR encryption at both sites.

G1 **No printed contact trees at FAC-B**

Escalation stalls when digital comms fail

G2 **Unclear authority to suspend the site VPN**

Containment of cross-site spread is delayed

G5 **No pre-scripted media holding statements**

Inconsistent external messaging

G8 **Veeam depends on the Hyper-V host it protects**

Backups may vanish with the host

CORRECTIVE ACTIONS CONFIRMED

R2 Emergency authority cards

R3 Phone-first reporting drills

R6 Offsite secondary backup host

90 days: stabilise, see, prove

Phase 1 · Days 1-30

Stabilise & assign

- Remove internet-facing RDP
- MFA for priority accounts and remote access
- Isolate backup credentials
- Emergency contact and downtime packs

Phase 2 · Days 31-60

Visibility & verification

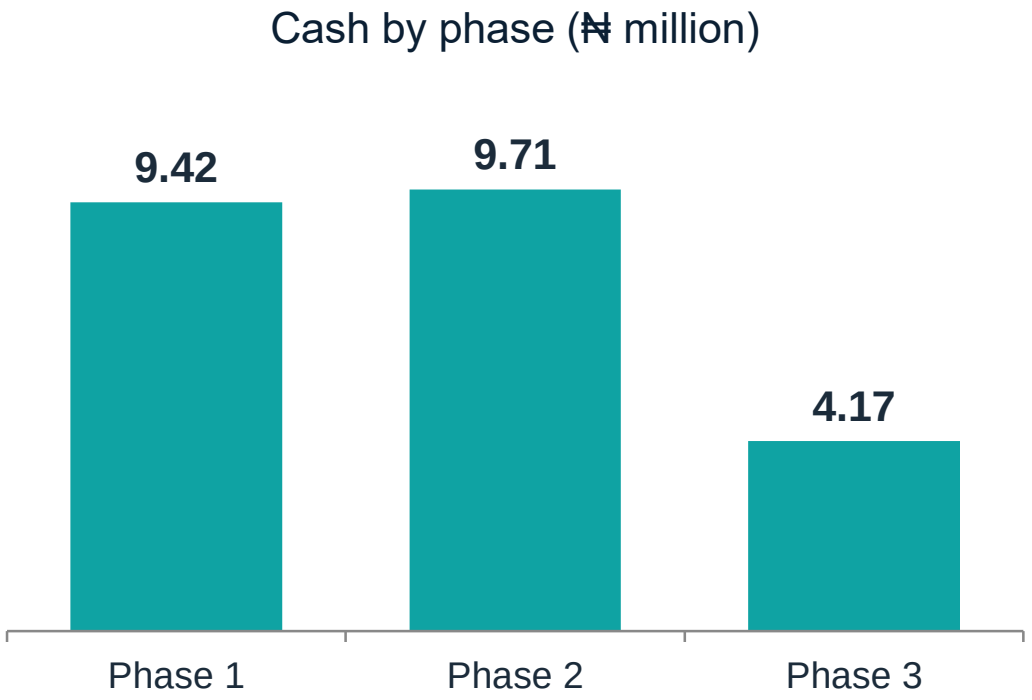
- Defender for Business plus server protection
- Wazuh central logging
- VLAN segmentation Z1 to Z7
- Individual vendor accounts
- First timed restore test

Phase 3 · Days 61-90

Prove & embed

- Windows Server migration
- Endpoint modernisation
- Second tabletop exercise
- Reassess risks, monthly dashboard

The investment: ₦26.8m cash over 90 days



Cash subtotal	₦23.300m
Contingency (15%)	₦3.495m
Cash requirement	**₦26.795m**
Absorbed internal labour	₦3.600m
Full economic cost	**₦30.395m**

Plus ₦8.34m a year in recurring subscriptions: Entra ID P1, Defender for Business and a password vault.

Cybersecurity Management Dashboard

Cybersecurity Risk Assessment & Ransomware Resilience Strategy | Management Performance Overview | FAC-A and FAC-B

PROJECT SCOPE

Simulated
Environment

02
Healthcare facilities

~80
Staff in scope

15
Risk scenarios

CONTROL VALIDATION

9/9
RBAC decisions: expected access decisions passed

3/3
File recovery: synthetic files hash-verified

07
Network zones: proposed segmentation architecture

06 / 10
Tabletop exercise: injects completed / decisions recorded

RECOVERY AND INVESTMENT INDICATORS

4 hrs
Planned RTO, not yet proven

24 hrs
Planned RPO, requires validation

₦26.795 m
90-day cash investment estimate

₦30.395 m
Full economic cost estimate

MANAGEMENT ATTENTION

HIGH PRIORITY **SV-01 / Veeam dependency**

The Veeam recovery environment (SV-06) depends on SV-01. Loss of the host could delay recovery while replacement infrastructure and the backup environment are rebuilt.

UNVERIFIED **Production readiness**

Laboratory and tabletop outcomes do not demonstrate live production protection or full multi-server recovery.

DECISIONS REQUIRED FROM MANAGEMENT

1. Approve the phased 90-day cybersecurity improvement budget.
2. Assign accountable owners to each security control.
3. Remove the SV-01/Veeam single point of failure.
4. Conduct an end-to-end recovery exercise to validate RTO and RPO.

Approve. Assign. Prove.

Resilience is people, process, technology and recovery, not tools alone.



Close the door

Remove internet-facing RDP; enforce MFA on remote and privileged access.

Protect the backups

Isolate backup credentials, back up FAC-B and break the SV-01 dependency.

Prove recovery

Run a timed, end-to-end restore to validate the 4-hour RTO and 24-hour RPO.

THANK YOU

